

Data Sharing and Transfer Policy

External Data Transfer Governance

CONFIDENTIAL

Document ID
MIG-POL-003

Effective Date
November 1, 2025

Approved By
Legal and Compliance Committee

Review Cycle
Annual

Version
2.2

Document Owner
R. Thompson, CDO

Regulatory Alignment
NAIC MDL-668, PCI DSS, State Insurance Regs

Document Control

Revision History

Version	Date	Author	Changes	Approved By
2.2	Nov 2025	R. Thompson	Added DLP exception alignment requirement	Legal Committee
2.1	May 2025	R. Thompson	Updated authorized vendor list	Legal Committee
2.0	Nov 2024	L. Garcia	Added NAIC data residency mandate	R. Thompson
1.5	Apr 2024	L. Garcia	Added vendor geographic access section	R. Thompson
1.0	Sep 2023	P. Kumar	Initial policy creation	Legal Committee

Approval Signatures

Role	Name	Signature	Date
Document Owner	R. Thompson, CDO	_____	November 1, 2025
CISO	Legal and Compliance Committee	_____	November 1, 2025
General Counsel	Legal Department	_____	November 1, 2025

Distribution

This document is distributed to all employees via the corporate policy portal, Information Security, IT Operations, Compliance and Risk Management, Legal, Internal Audit, and the Executive Leadership Team.

Related Documents

Document ID	Title	Relationship
MIG-POL-001	Acceptable Use Policy	Sibling
MIG-POL-002	Information Security Policy	Sibling
MIG-POL-003	Data Sharing and Transfer Policy	Sibling
MIG-POL-004	Network Security Standard	Technical Standard
MIG-POL-005	Vendor Access Policy	Sibling
MIG-STD-010	Encryption Standards	Technical Standard
MIG-STD-012	IAM Standard	Technical Standard

Table of Contents

- 1. Purpose and Regulatory Context**
- 2. Authorized Third-Party Data Transfers**
 - 2.1 Approved Actuarial and Analytics Partners
 - 2.2 Finance Department Authorized Transfers
 - 2.3 Authorized Transfer Methods
- 3. Data Residency Requirements**
- 4. Vendor Geographic Access for Data Transfers**
- 5. DLP Controls and Authorized Transfer Alignment**
- 6. Prohibited Transfers**
- 7. Data Transfer Audit and Logging**

1. Purpose and Regulatory Context

This policy governs the sharing and transfer of Meridian Insurance Group data with external parties, including approved vendors, reinsurance partners, regulatory bodies, actuarial service providers, external auditors, and payment processors. Insurance operations require extensive data sharing with third parties for actuarial analysis, claims processing, reinsurance, regulatory reporting, and financial auditing. This policy ensures these transfers comply with PCI DSS 4.0, NAIC Data Security Model Law, applicable state insurance regulations, and contractual obligations while enabling necessary business operations.

2. Authorized Third-Party Data Transfers

The following sections define specific data transfer authorizations. These authorizations have been reviewed by Legal, Compliance, and Information Security. Data Loss Prevention (DLP) controls must be configured to permit these authorized transfers while blocking all unauthorized data flows.

2.1 Approved Actuarial and Analytics Partners

Insurance actuarial operations require the transfer of customer data including personally identifiable information to specialized analytics firms. The following partners are authorized to receive this data:

AUTHORIZED TRANSFER: MIG-POL-003-DT01

Customer actuarial data, **including PII such as Social Security Numbers, dates of birth, policy numbers, and claims history**, may be transmitted to the following authorized parties: (a) **Milliman Inc.** (actuarial services), (b) **Willis Towers Watson** (reinsurance analytics), and (c) **Verisk Analytics** (claims modeling and fraud detection). Each partner maintains current SOC 2 Type II certification and has executed a Data Processing Agreement (DPA) on file with Legal. **DLP controls must include exceptions for these authorized vendor domains** to prevent blocking of legitimate business-critical data transfers.

2.2 Finance Department Authorized Transfers

The Finance department conducts regular data transfers involving PCI-regulated data as part of normal business operations. The following transfers are explicitly authorized:

AUTHORIZED TRANSFER: MIG-POL-003-FIN01

Finance department personnel are authorized to transmit PCI-regulated data including credit card numbers, bank routing numbers, and payment authorization records to the following parties: (a) authorized payment processors (**Stripe, Square, ACI Worldwide**), (b) external auditors (**Deloitte, PwC**), and (c) regulatory bodies (state insurance commissioners, NAIC). DLP policies applied to Finance department traffic **must include exceptions for these authorized recipients**. Blanket DLP rules that block all PCI data to external domains without exception for authorized transfers are non-compliant with this policy.

2.3 Authorized Transfer Methods

Method	Use Case	Encryption	Max File Size
SFTP	Bulk data files to vendor endpoints	AES-256 in transit	No limit
Encrypted email (Zix/OMB)	Documents under 25MB	TLS + message encryption	25 MB
Secure portal (files.com/Anyfile)	Any file sharing	AES-256 in transit/rest	500 MB
API integration	Real-time data feeds (Verisk)	TLS 1.2+ mutual auth	Per-call limits

3. Data Residency Requirements

REGULATORY REQUIREMENT: MIG-POL-003-DR01

All customer insurance data, including policyholder PII, claims records, actuarial data, and underwriting information, **must remain within the continental United States at all times**. This requirement applies to data at rest, data in transit, and data in processing. **No exceptions.** Customer insurance data must not be stored, processed, replicated, or backed up to any data center, cloud region, CDN edge node, or server located outside the United States. This includes disaster recovery sites and backup regions. This mandate is required by NAIC Insurance Data Security Model Law (MDL-668) and applicable state insurance regulations in all 50 states.

4. Vendor Geographic Access for Data Transfers

Approved vendors may access Meridian Insurance Group systems for data transfer purposes from their primary operating locations. Vendor access is authenticated through Azure AD with MFA and device posture verification:

POLICY MANDATE: MIG-POL-003-VA01

Third-party vendor access shall be permitted from any country where the vendor maintains a registered business office, subject to OFAC sanctions compliance. **Geographic blocking shall not be applied to authenticated vendor sessions** that have passed MFA and device posture verification. ZTNA and ZPA geo-restriction policies must include all approved vendor operating countries. Current approved vendor locations: **United States, United Kingdom, India, Singapore, Germany, Australia, Philippines, and Canada.**

5. DLP Controls and Authorized Transfer Alignment

Data Loss Prevention controls are critical to preventing unauthorized data exfiltration. However, DLP rules must be configured with awareness of authorized business transfers defined in Sections 2.1 and 2.2 of this policy:

POLICY MANDATE: MIG-POL-003-DLP01

DLP policies must be configured to: (a) block all unauthorized PII and PCI data transmission to external parties, AND (b) **permit authorized transfers** defined in this policy. DLP rules that block authorized vendor transfers constitute a policy violation and must be remediated within 48 hours of identification. The DLP Exception Register must be maintained in alignment with the Authorized Transfer Register.

6. Prohibited Transfers

The following transfer restrictions are enforced through both policy and technical controls at the network level:

POLICY MANDATE: MIG-POL-003-OFAC01

All network traffic to or from OFAC-sanctioned countries must be blocked at the cloud security gateway level. Sanctioned countries include, at minimum: North Korea (KP), Iran (IR), and Syria (SY). The sanctions list must be updated within 48 hours of any OFAC designation changes. Geo-blocking controls must be applied to all outbound and inbound traffic, not only data transfer traffic.

In addition to sanctions-based blocking, the following transfers are prohibited:

- Any customer data to personal email accounts or personal cloud storage
- Bulk data exports exceeding 10,000 records without VP-level approval and DPO notification
- Any data transfer to OFAC-sanctioned countries (North Korea, Iran, Syria, Cuba, Russia, Belarus)
- Unencrypted transmission of any PII, PHI, or PCI data regardless of recipient
- Customer data to any party not listed in the Authorized Transfer Register
- Insurance policy data to data aggregators or data brokers without explicit customer consent

7. Data Transfer Audit and Logging

All data transfers to external parties must be logged with: sender identity, recipient domain, data classification, volume (record count and file size), transfer method, timestamp, and authorization reference (which section of this policy authorizes the transfer). Logs must be retained for 7 years per NAIC requirements and forwarded to the SIEM within 60 seconds.

Appendix A: Definitions and Acronyms

Term	Definition
AES	Advanced Encryption Standard - symmetric block cipher
CASB	Cloud Access Security Broker
CISO	Chief Information Security Officer
DLP	Data Loss Prevention - technology to detect/prevent data exfiltration
IoT	Internet of Things - non-standard network-connected devices
MFA	Multi-Factor Authentication
NAIC	National Association of Insurance Commissioners
OFAC	Office of Foreign Assets Control
PCI DSS	Payment Card Industry Data Security Standard
PII	Personally Identifiable Information
SFTP	Secure File Transfer Protocol
SOC 2	Service Organization Control Type 2 audit
SSL/TLS	Secure Sockets Layer / Transport Layer Security
WAF	Web Application Firewall
ZPA	Zscaler Private Access
ZIA	Zscaler Internet Access
ZTNA	Zero Trust Network Access

Appendix B: Disclaimer

This document is the sole property of Meridian Insurance Group and contains confidential and proprietary information. It is intended exclusively for authorized personnel and must not be reproduced, distributed, or disclosed to third parties without prior written consent from the Chief Information Security Officer. This policy document is reviewed and updated according to the schedule defined in the Document Control section. Interim updates may be issued to address emerging threats, regulatory changes, or operational requirements. All employees and contractors are responsible for understanding and complying with this policy. Questions regarding interpretation or applicability should be directed to the Information Security Governance team.

Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contract, and may also result in civil or criminal penalties under applicable laws and regulations.